SE LAB 5 : Static Code Analysis

PES2UG24CS483
Shreya Narayana Bhat

Before :

```
(venv) PS C:\Users\iamsh\Desktop\SE\SE_Lab5\Shreya-Bhat-2006-L5-Static-Code-Analysis_PES2UG24CS483> Get-Content pylint_before.txt
************ Module employee_payroll_system
employee_payroll_system.py:73:0: C0304: Final newline missing (missing-final-newline)
employee_payroll_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
employee_payroll_system.py:15:0: C0103: Function name "processSalary" doesn't conform to snake_case naming style (invalid-name)
employee_payroll_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
employee_payroll_system.py:19:28: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
employee_payroll_system.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
employee_payroll_system.py:26:4: W0702: No exception type(s) specified (bare-except)
employee_payroll_system.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
employee_payroll_system.py:32:7: C0121: Comparison 'payroll_records.get(emp_id) == None' should be 'payroll_records.get(emp_id) is None' (singleton-comparison)
employee_payroll_system.py:34:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
employee_payroll_system.py:34:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
employee_payroll_system.py:31:4: W0612: Unused variable 'statutory_buffer' (unused-variable)
employee_payroll_system.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
employee_payroll_system.py:42:10: W0123: Use of eval (eval-used)
employee_payroll_system.py:41:4: W0612: Unused variable 'base' (unused-variable)
employee_payroll_system.py:46:0: C0116: Missing function or method docstring (missing-function-docstring)
employee_payroll_system.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
employee_payroll_system.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
employee_payroll_system.py:55:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
employee_payroll_system.py:55:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
employee_payroll_system.py:61:0: C0116: Missing function or method docstring (missing-function-docstring)
employee_payroll_system.py:6:0: W0611: Unused import math (unused-import)
```

```
--------------------------------------------------------------------
Your code has been rated at 5.32/10 (previous run: 10.00/10, -4.68)

(venv) PS C:\Users\iamsh\Desktop\SE\SE_Lab5\Shreya-Bhat-2006-L5-Static-Code-Analysis_PES2UG24CS483> Get-Content bandit_before.txt
python : [main] INFO    profile include tests: None
At line:1 char:1
+ python -m bandit -r employee_payroll_system.py > bandit_before.txt 2> ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: ([main]     INFO    profile include tests: None:String) [], RemoteE
   xception
    + FullyQualifiedErrorId : NativeCommandError

[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.10
Run started:2026-10-14 08:15:53.181825+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\employee_payroll_system.py:26:4
```

```
--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\employee_payroll_system.py:51:11
50      def generate_payroll_token():
51          return random.randint(1000, 9999)
52

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\employee_payroll_system.py:58:4
57          f.close()
58          os.system("echo Payroll summary exported to: " + filename)
59


--------------------------------------------------

Code scanned:
        Total lines of code: 53
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0
```

```
Code scanned:
        Total lines of code: 53
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

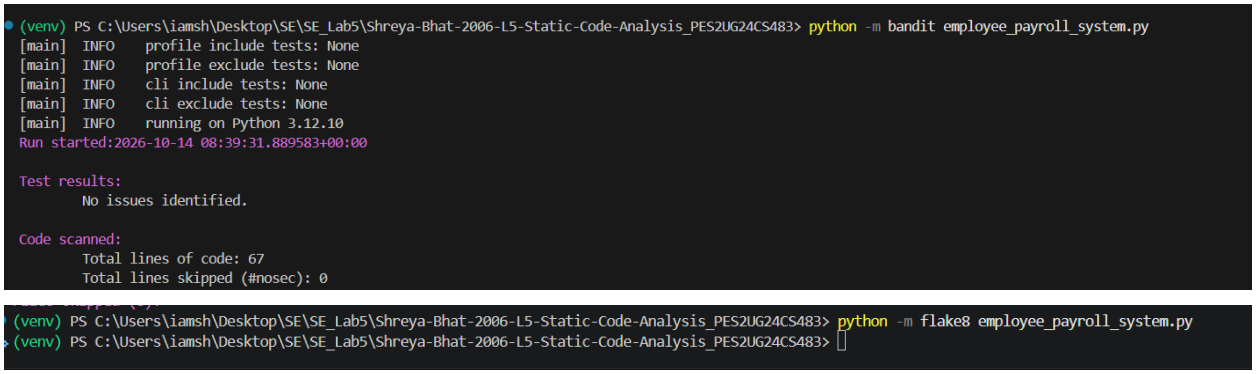
Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 5
Files skipped (0):
(venv) PS C:\Users\iamsh\Desktop\SE\SE_Lab5\Shreya-Bhat-2006-L5-Static-Code-Analysis_PES2UG24CS483> Get-Content flake8_before.txt
employee_payroll_system.py:6:1: F401 'math' imported but unused
employee_payroll_system.py:19:80: E501 line too long (84 > 79 characters)
employee_payroll_system.py:26:5: E722 do not use bare 'except'
employee_payroll_system.py:31:5: F841 local variable 'statutory_buffer' is assigned to but never used
employee_payroll_system.py:32:36: E711 comparison to None should be 'if cond is None:'
employee_payroll_system.py:41:5: F841 local variable 'base' is assigned to but never used
employee_payroll_system.py:73:7: W292 no newline at end of file
```

After :

```
(venv) PS C:\Users\iamsh\Desktop\SE\SE_Lab5\Shreya-Bhat-2006-L5-Static-Code-Analysis_PES2UG24CS483> python -m pylint employee_payroll_system.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)

(venv) PS C:\Users\iamsh\Desktop\SE\SE_Lab5\Shreya-Bhat-2006-L5-Static-Code-Analysis_PES2UG24CS483>
```



Known Issue Table

Issue	Type	Line(s)	Description	Fix Approach
Unused import (`math`)	Code Quality	6	Imported module is never used	Removed the unused import
Function naming convention	Code Quality	12	`processSalary` does not follow snake_case	Renamed to `process_salary`
Mutable default argument	Bug	13	`transaction_logs=[]` is shared across function calls	Changed default to None and initialized inside the function
Bare `except`	Bug / Code Quality	25–26	Catches all exceptions and silently ignores errors	Removed broad exception handling and validated inputs
Unused variable `statutory_buffer`	Code Quality	30	Variable is assigned but never used	Removed the variable
Comparison with `None`	Code Quality	31	Uses `== None` instead of the recommended identity check	Changed to `is None`

Issue	Type	Line(s)	Description	Fix Approach
Long line	Style	31	A line exceeds the recommended length	Reformatted the code
Unsafe `eval()`	Security	36	Executes an expression dynamically and may allow malicious code	Replaced with direct salary calculation using a deduction rate
Unused variable `base`	Code Quality	37	Variable is assigned but not used meaningfully	Replaced with direct salary calculation
Weak MD5 hash	Security	41	MD5 is not suitable for secure hashing	Replaced MD5 with SHA-256
Insecure random token	Security	45	`random.randint()` is not intended for security-sensitive tokens	Replaced it with `secrets.randbelow()`
File handling without context manager	Code Quality	49–51	File is opened and closed manually	Used `with open()` and UTF-8 encoding
Unsafe `os.system()`	Security	52	Runs a system command unnecessarily	Replaced it with `print()`
Missing function docstrings	Code Quality	Multiple	Functions do not explain their purpose	Added function docstrings
Missing final newline	Style	End of file	File does not end with a newline	Added a final newline